

Protocoles de sécurité Wi-Fi

- ▶ Les protocoles de sécurité Wi-Fi appliquent le chiffrement pour sécuriser les réseaux et protéger les données. Étant donné que les réseaux sans fil sont généralement moins sûrs que les réseaux filaires, les protocoles de sécurité sont essentiels pour garantir votre sécurité en ligne.
- ▶ Les protocoles de sécurité Wi-Fi les plus courants actuellement sont WEP, WPA, WPA2 et WPA3.

Le WEP

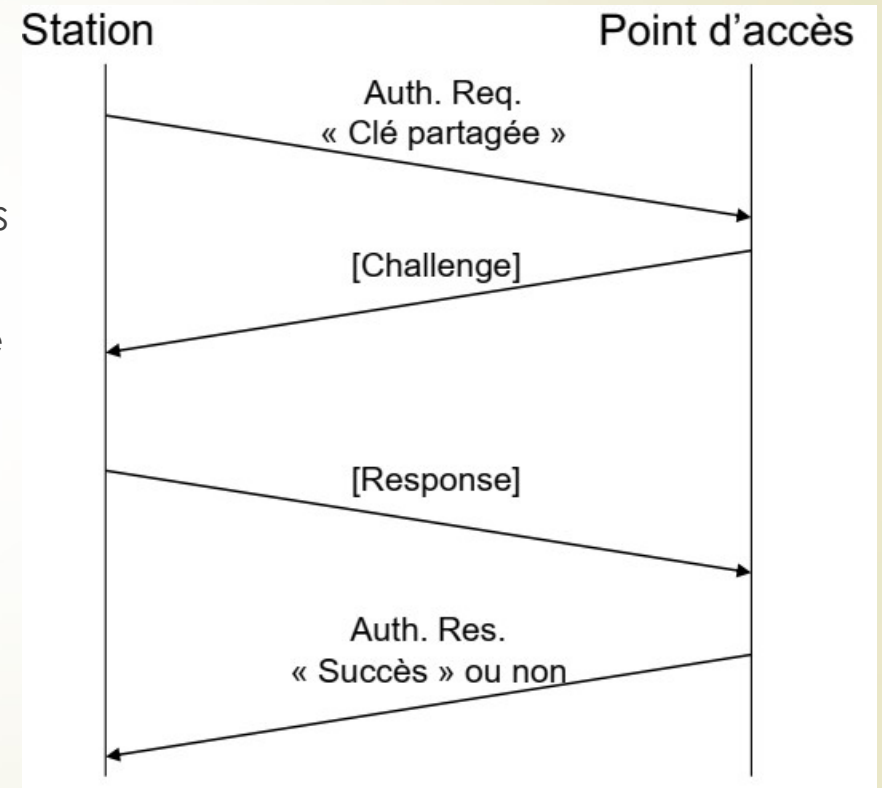
- Conscient de ces enjeux la norme IEEE 802.11 a introduit un protocole de sécurité **WEP** (Wired Equivalent Privacy) , qui a pour objectif d'assurer les fonctions suivantes :
 - Authentification d'un utilisateur.
 - Confidentialité des données échangées sur les canaux radio.
 - Garantie de l'intégrité des données.
- Principe : Chiffre le corps de la trame MAC et le CRC avec RC4 (algorithme de cryptage) en utilisant des clefs de 64 ou 128 bits. Le chiffrement n'est utilisé qu'entre les éléments 802.11. Il ne s'applique plus sur le réseau filaire.

Le WEP

- ▶ Le WEP repose sur un algorithme appelé RC4. Cet algorithme a été conçu par Ron Rivest en 1987 pour RSA Security. RC4 Rivest Cipher 4 c'est-à-dire « code de Rivest numéro 4 »
Il s'agit d'un chiffrement par flot à clé variable avec des opérations orientées octet. L'algorithme est basé sur : l'utilisation d'une permutation aléatoire.

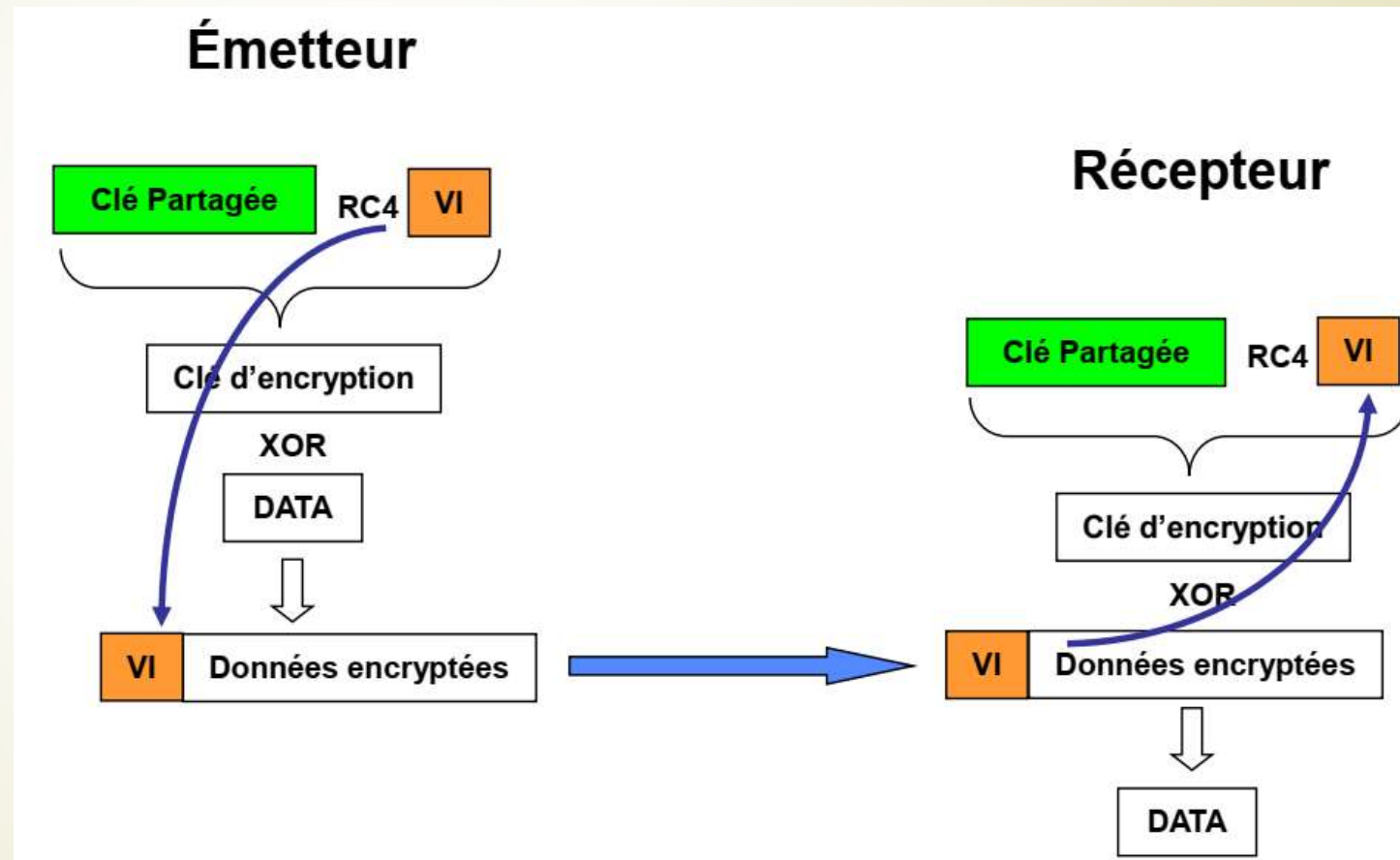
Authentification dans le WEP

- La station transmet une requête d'authentification (Authentication Request).
- Le point d'accès produit un challenge (Authentication Challenge) qui comporte 128 octets en clair.
- La station encode ce nombre de 128 octets à l'aide d'une trame WEP (Authentication Response), associée à un IV 24 bits et un KeyID de 2 bits.
- Le point d'accès notifie l'échec ou la réussite de l'opération (Authentication Result).



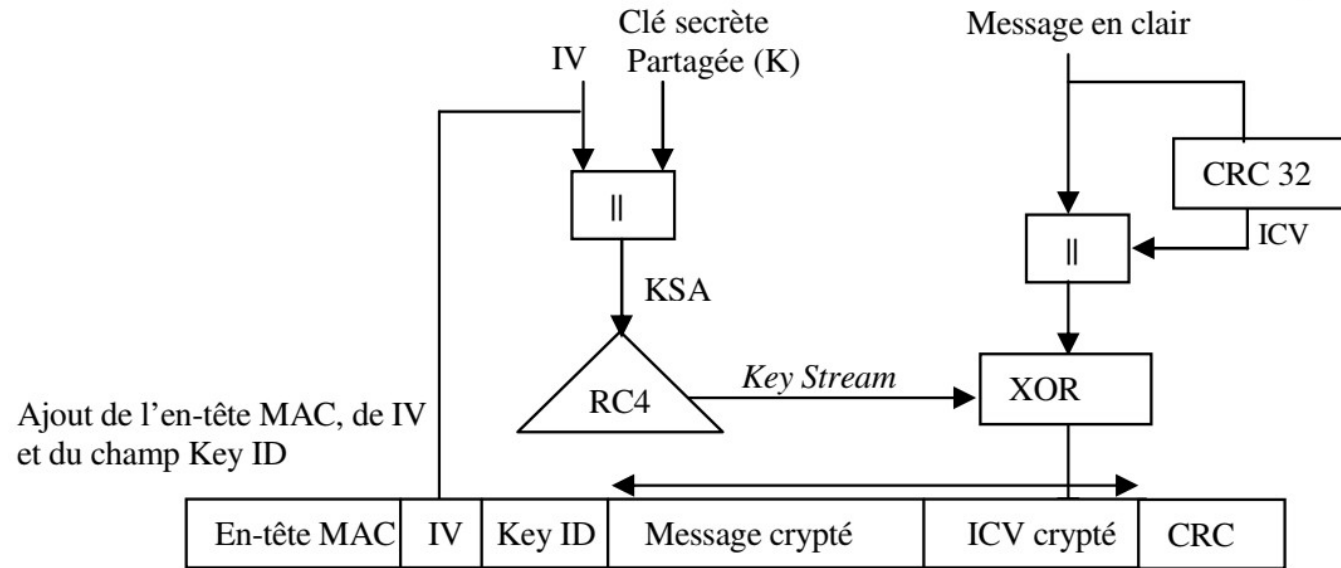
Le WEP

- la clé secrète a une longueur de 40 ou 104 bits.
- Cette clé secrète doit être déclarée au niveau du point d'accès et des clients
- Le vecteur d'Initialisation **IV(Initialization Vector)** est de 24 bits



Le chiffrement et le contrôle d'intégrité

- **ICV : Integrity Check Value (Cyclic Redundancy Code sur 32 bits)**
- **IV: vecteur d'initialisation sur 24 bits**
- **K : clé secrète partagée par l'AP et les clients (40 ou 104 bits)**
- **Key-stream RC4 (IV | K): résultat de l'algorithme RC4 initialisé par IV et K**



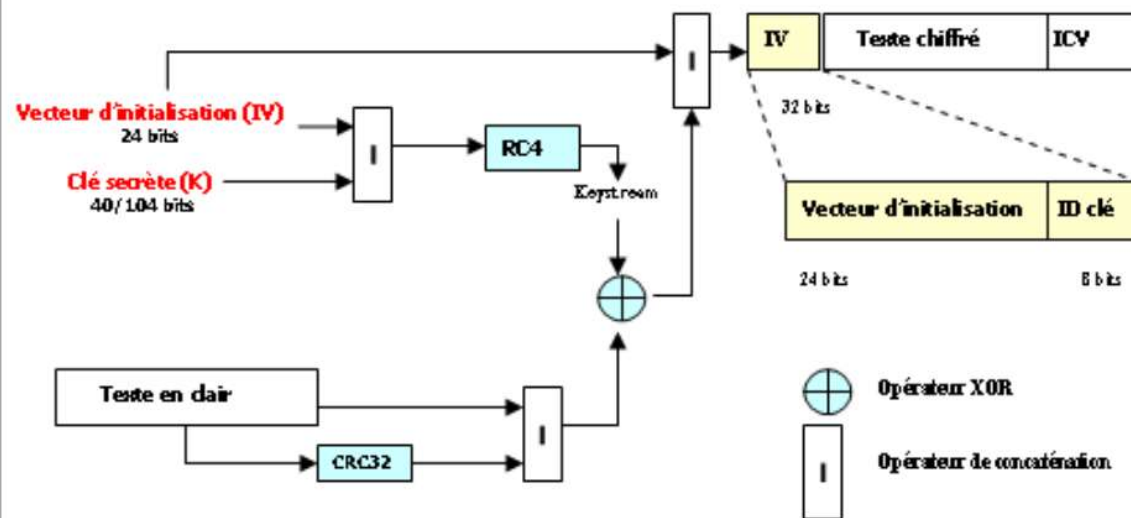
Le chiffrement et le contrôle d'intégrité

- ▶ La clé partagée K de 40 ou 104 bits est concaténée avec un vecteur d'initialisation (IV) de 24 bits formant ainsi une clé de 64 ou 128 bits appelée *Key Scheduling Algorithm* (KSA) : $KSA = [IV \parallel K]$.
- ▶ L'algorithme RC4 est appliqué sur la clé KSA pour produire une série pseudo aléatoire de bits d'une longueur égale à la longueur de la trame, nommée KeyStream (KS) : $KS = RC4 [IV \parallel K]$.
- ▶ Un XOR est appliqué bit à bit entre la KeyStream et les données concaténées avec l'ICV, formant les données cryptées :
$$C = [M \parallel ICV(M)] \oplus RC4 [IV \parallel K].$$
 Où $\oplus$ est l'opération XOR.
- ▶ Les données chiffrées sont transmises et l'IV est rajouté à la trame.

Le déchiffrement et le contrôle d'intégrité

- La clé partagée est concaténée avec l'IV de la trame reçue, puis l'ensemble est soumis à l'algorithme RC4 pour donner la bonne séquence pseudo aléatoire qui a été utilisé pour le chiffrement
- On effectue un XOR entre cette séquence aléatoire et les données chiffrées reçues. On obtient les données et l'ICV en clair de la façon suivante :
- $$\begin{aligned}
 C + \text{RC4} [\text{IV} \parallel K] &= [M \parallel \text{ICV} (M)] + \text{RC4} [\text{IV} \parallel K] + \text{RC4} [\text{IV} \parallel K] \\
 &= [M \parallel \text{ICV} (M)] + (\text{RC4} [\text{IV} \parallel K] + \text{RC4} [\text{IV} \parallel K]) \\
 &= [M \parallel \text{ICV} (M)]
 \end{aligned}$$
- On effectue un contrôle d'intégrité (ICV') sur ces données en clair que l'on compare avec l'ICV reçu. Si $\text{ICV}' = \text{ICV}$ on peut être sûr des données.

Construction du texte chiffré



Opérations de chiffrement
et de déchiffrement
(schéma complet)

Déchiffrement du texte

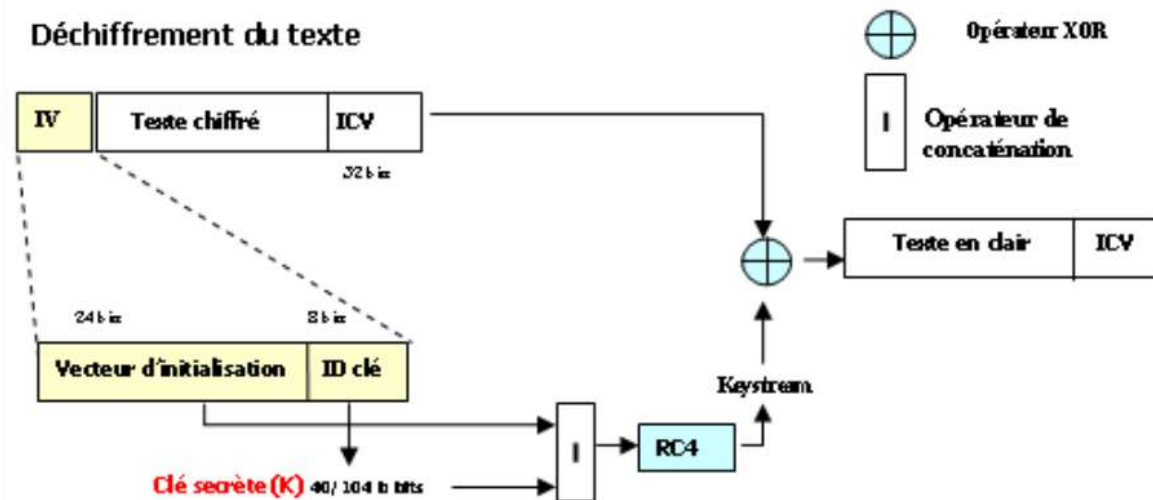


schéma extrait du magazine MISC informatique

Vulnérabilités WEP

- **Spoofing** de l'authentification : le principe de l'authentification avec WEP est que le point d'accès envoie un challenge de 128 octets en clair, L'attaque peut être réalisée en interceptant le message en clair et la réponse cryptée. Ensuite, l'attaque déduit RC4 (IV, K) et il demande à s'authentifier

Le chiffrement RC4 (C_i) est réalisé par le ou exclusif (code de Vernam) du message (M_i) en clair avec suite d'octets pseudo aléatoire X_{si} déduit de la clé.

On peut déduire la valeur de la clé X_{si} connaissant la valeur en clair C_i .

$$C_i = M_i \oplus X_{si}, C_i \oplus M_i = X_{si}$$

- En raison de l'utilisation d'un vecteur d'initialisation relativement court (24 bits), il est fort probable que, après une courte période de temps sur un réseau sans fil actif, le vecteur IV sera réutilisé, une clé RC4 ne doit pas être réutilisée ($2^{24} = 16$ millions de trames chiffrées par clé)
- Cette faille est exactement située dans l'opération de génération de flux aléatoire. Les statistiques sur les premiers octets du flux généré montrent un certain biais qui permet de retrouver des informations sur la clé,

Vulnérabilités WEP

- Clé WEP statique. Dans WEP : la clé est partagée par tous les utilisateurs, elle change rarement.
- **Mauvaise protection de l'intégrité (ICV)**

WEP utilise un **CRC-32** pour vérifier l'intégrité des données.

Le CRC-32 : n'est **pas une fonction cryptographique**, il est **linéaire**

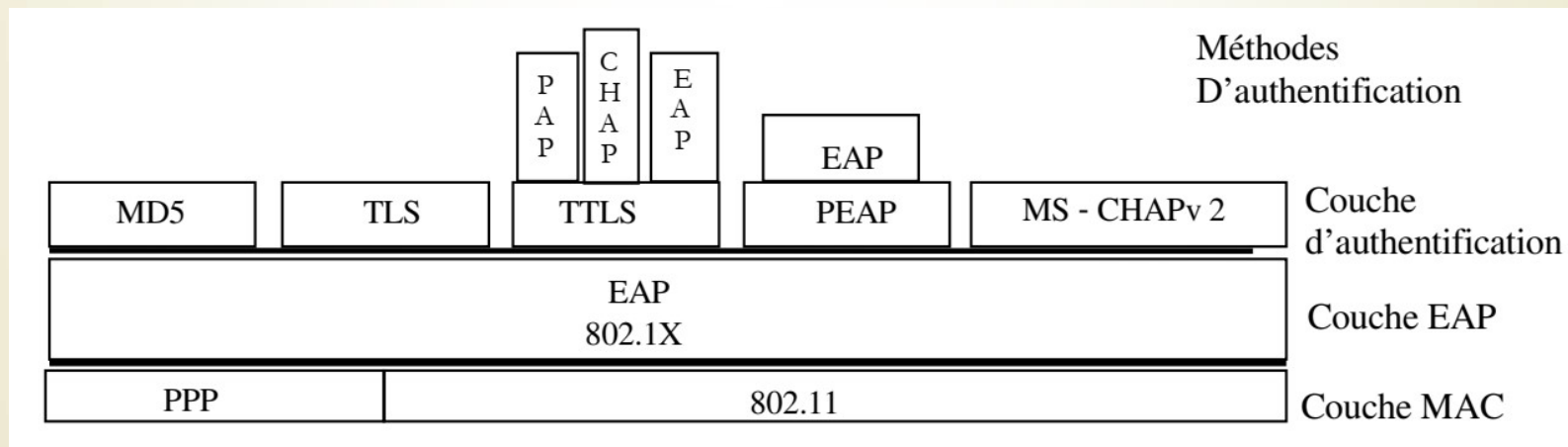
Conséquence : Un attaquant peut modifier un paquet, recalculer le CRC; envoyer le paquet modifié.
- Dans le WEP, la station mobile n'authentifie pas le point d'accès. Elle ne peut donc pas vérifier si elle s'accorde avec le vrai point d'accès ou non. Cela représente une faiblesse majeure qui peut être exploitée dans une attaque comme l'attaque "EVILL TWIN".

Le protocole IEEE 802.1X

- Le protocole IEEE 802.1X (ou *Port Based Network Access Control*) s'appuie sur trois entités fonctionnelles, L'idée centrale est de bloquer le flux de données d'un utilisateur non authentifié,
- La norme IEEE 802.1X utilise les termes:
 - 1) **Supplicant**, un terminal informatique désirant utiliser les ressources offertes par un réseau de communication.
 - 2) **Authenticator** : Le système qui contrôle un port d'accès au réseau,
 - 3) **Le serveur d'authentification** (RADIUS), **Remote Authentication Dial In User Service** il réalise la procédure d'authentification avec le supplicant. Le protocole d'authentification utilisé est Extensible Authentication Protocol (**EAP**).

Le protocole EAP

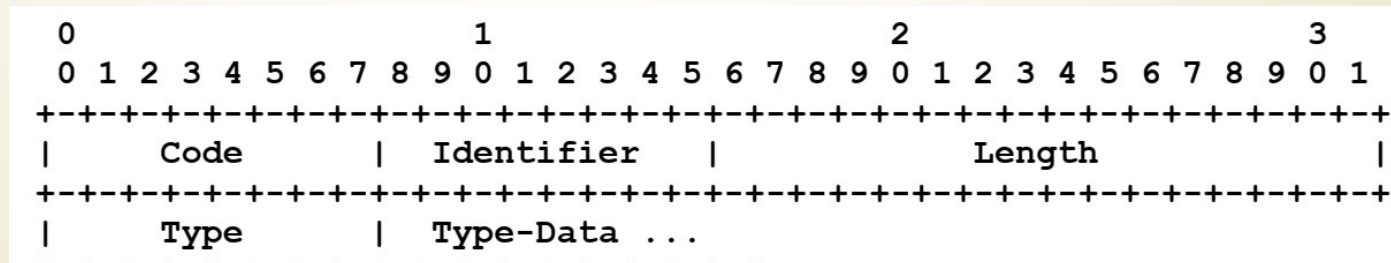
- ▶ Le standard IEEE 802.1X emploie le protocole EAP qui réalise une enveloppe générique pour de multiples méthodes d'authentification,
- ▶ EAP ne définit pas de méthode d'authentification particulière mais il définit un moyen de transport général pour les échanges d'authentification. Il repose sur le paradigme de communication challenge-response.



la pile EAP

Le protocole EAP

- Il existe quatre type de messages identifiés par un code (1 octet), requête (1=request), réponse (2=response), succès (3=Success) et échec (4=Failure).
- La requête et la réponse sont étiquetées par le même « Identifieur » compris entre 0 et 255 et elles
- Le champ « Length » représente la longueur du paquet EAP.
- Le champ « Type », dans des paquets de requêtes ou de réponses, désigne le protocole d'authentification transporté d'où le nom extensible



Format d'un message EAP

Le protocole EAP

Type=1, message relatif à l'identité (*Identity*)

Type=4, protocole d'authentification à base de défi MD5 (EAP-MD5)

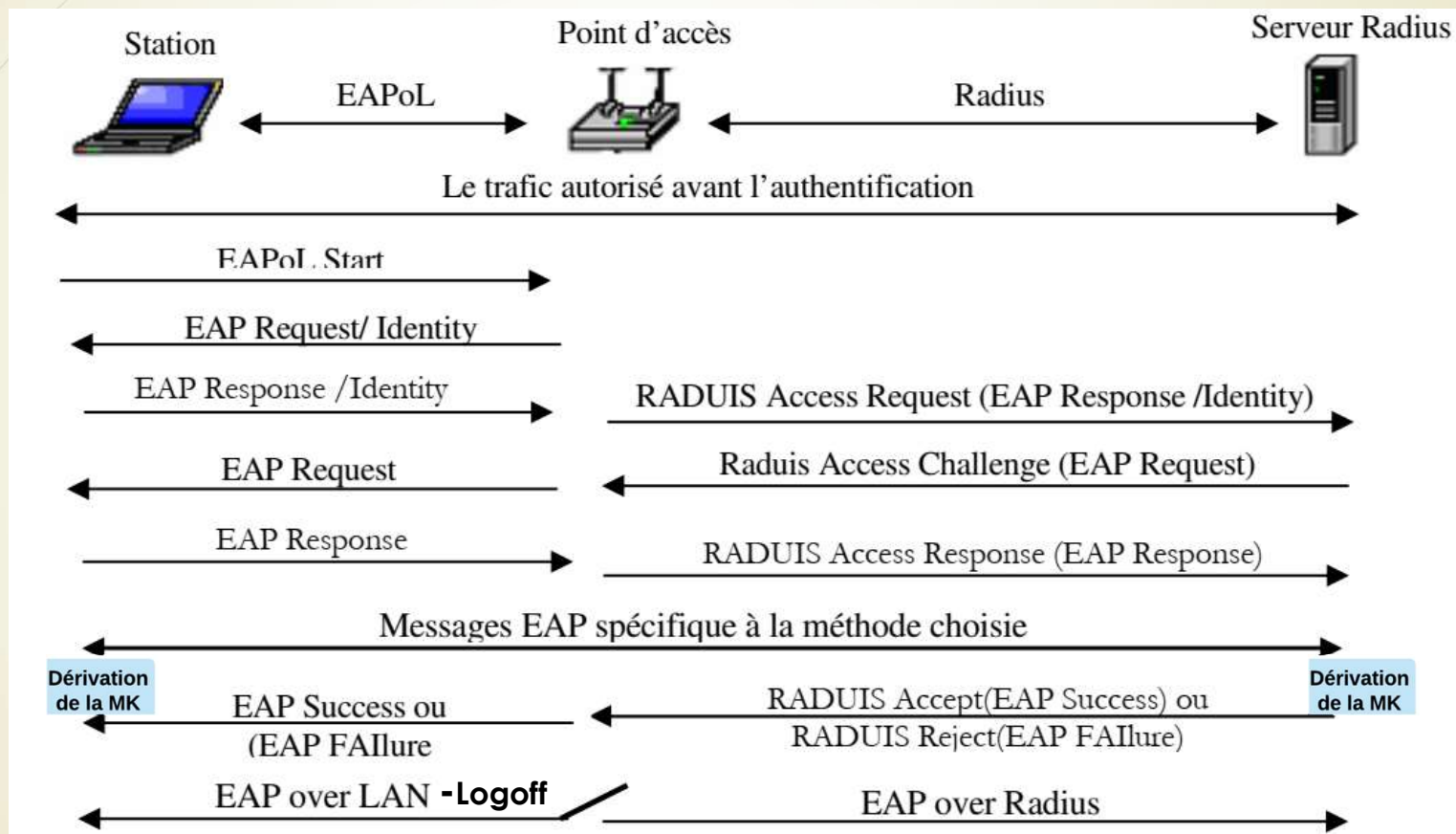
Type = 13, transport de TLS (EAP-TLS)

Type = 18 méthode d'authentification basée sur une carte SIM (EAP-SIM)

Type = 26, transport de MSCHAPv2.

- Les messages EAP sont eux même encapsulé, le protocole EAP Over LAN (EAPOL) transporte les paquets EAP entre la station et le point d'accès en faisant appelle au message suivant :
 - EAPoL-Start : permet au client de prévenir l'authentificateur qu'il souhaite se connecter ;
 - EAPoL-Packet : ce sont ces paquets qui encapsulent les paquets EAP.
 - EAPoL-Key : permet l'échange de clé de cryptage.
 - EAPoL-Logoff : permet au client de demander la fermeture de sa session.

Le protocole EAP



Le protocole EAP

- Le serveur d'authentification prend la décision d'accepter ou de refuser l'accès au réseau, comme, on aura 3 cas a cité :
- 1. Si l'authentification est réussie, RADUIS envoie le message EAP-Success à la station mobile pour indiquer le succès de la procédure d'authentification. Le *port contrôlé* passe alors à l'état autorisé.
- 2. Si l'authentification a échoué le message EAP-Failure sera envoyé, dans ce cas le port reste dans l'état non autorisé.
- 3. Si l'authentification est réussie et la station mobile veut se déconnecter de point d'accès courant, elle lui envoie un paquet EAPOL-Logoff, le port contrôlé transite alors à l'état non autorisé.